

한전KPS(주) 상임감사

개 선 · 시 정 요 구

일련번호 2024-☆☆☆☆처-005

제 목 “OTP(One Time Password)시스템” 권한 관리 미흡

관계부서 ☆☆☆☆처

조치부서 ☆☆☆☆처

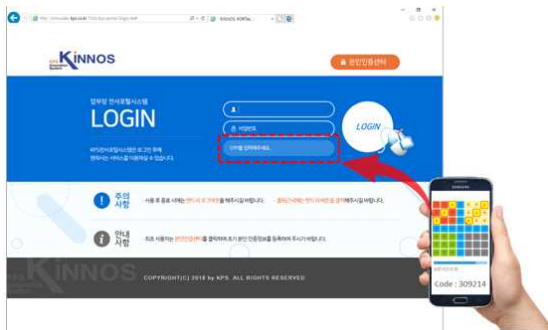
내 용

1. 업무개요

「정보시스템 보안관리기준」 제26조(사용자계정) 제3항에 따라 회사는 통합인증(SSO)¹⁾ 시스템을 활용하여 다수의 정보시스템을 대상으로 사용자 인증을 통합하여 운영하고 있으며, 정보보안을 강화하기 위하여 전사포탈 로그인 시, 비밀번호에 병행하여 일회용 비밀번호 생성기(OTP)²⁾를 사용하고 있다. OTP생성기는 [그림 1]과 같이 사용자 휴대폰의 어플리케이션을 통해 제공된다.

한편, 해외 등 통신상황이 불안정한 경우 OTP 없이 전사포탈에 로그인 할 수 있도록 별도의 신청서를 받아 OTP 예외 처리를 하고 있으며, 사용자가 휴대폰을 변경/분실한 경우는 [그림 2]와 같이 화면OTP(1.5팩터)³⁾를 10일간 사용할 수 있도록 권한 부여 후 회수하고 있다.

[그림 1] OTP 사용방법



[그림 2] 화면OTP(1.5팩터)



- 1) 통합인증(SSO:Single Sign On) : 한 번의 인증 과정으로 여러 컴퓨터 상의 자원을 이용 가능하게 하는 인증 기능
- 2) 무작위 번호약속 알고리즘에 따라 매 시간마다 변경되는 추정할 수 없는 비밀번호 생성을 이용한 보안 시스템
- 3) 휴대폰이 아닌 브라우저에 OTP 패턴화면을 출력하는 기능

2. 판단기준

「회사정보보호규정」 제29조(전산시스템 보안관리) 제2항에 따르면, 사내 전산망의 사용권한은 업무효율을 해치지 않는 범위내에서 최소로 관리하며, 주관부서는 반기에 한 번씩 권한승인내역에 대해 조사하고 재조정하여야 한다.

따라서, ☆☆☆☆처(○○○○○부)는 반기에 한번씩 OTP 권한에 대하여 권한승인 내역을 확인하고 검토하여 이상이 있는 경우 권한을 재조정함으로써 회사의 중요 정보가 유출되지 않도록 하여야 한다.

3. 감사결과 확인된 문제점

그런데 ☆☆☆☆처(○○○○○부)는 OTP 예외 처리에 대한 명확한 기준 없이 신청서(통지)만을 받아 예외 처리하는 것으로 확인되었고, 또한, 2024.10.31. 기준 [표1]과 같이 총 25명에 대해서는 별도의 신청서가 없는데도 OTP 예외 처리가 되었다. 그리고 OTP 단말 분실신고 이후 화면 OTP 사용 권한 회수 기능 오류로 인해 2024.10.31. 기준 [표2]와 같이 2,015명에 대한 권한이 회수 되지 않아 현재도 해당 직원들은 인터넷망에서 화면 OTP(1.5 팩터)를 사용하고 있는 것으로 확인되었다.

[표1] OTP 예외처리 신청서 누락내역

구분	소속	사번	이름	망구분	비고
1	◆◆◆◆◆	♠♠♠005♠	■■■■■	업무망	통지누락
2	▽▽▽▽본부	♠♠♠000♠	■■■■■	업무망	통지누락
3	○○○○○본부	♠♠♠000♠	■■■■■	업무망	통지누락
4	◆◆◆◆◆	♠♠♠005♠	■■■■■	인터넷망	통지누락
5	▽▽▽▽본부	♠♠♠000♠	■■■■■	인터넷망	통지누락
⋮					
21	△△△△△실	♠♠♠205♠	■■■■■	업무망	통지누락
22	▲▲▲▲▲처	♠♠♠142♠	■■■■■	업무망	통지누락
23	▽▽▽▽▽소	♠♠♠004♠	■■■■■	업무망	통지누락
24	△△△△△실	♠♠♠205♠	■■■■■	인터넷망	통지누락
25	▲▲▲▲▲처	♠♠♠142♠	■■■■■	인터넷망	통지누락

[표2] 화면OTP(1.5팩터) 권한회수 오류내역

구분	소속	사번	이름	비고
1	▼▼▼▼소	♠♠♠93	☒☒☒	인터넷망
2	◁◁◁◁소	♠♠♠89	☆★☆	
3	▷▷▷▷처	♠♠♠35	☆★★	
4	▶▶▶▶소	♠♠♠75	★★☆	
5	♠♠♠♠♠♠처	♠♠♠56	★☆☆	
⋮				
2,011	♠♠♠♠소	♠♠♠027♠	○○●	인터넷망
2,012	♡♡♡♡♡지사	♠♠♠028♠	○●○	
2,013	♥♥♥♥♥실	♠♠♠029♠	●○○	
2,014	♣♣♣♣사	♠♠♠025♠	●●○	
2,015	♣♣♣♣사	♠♠♠017♠	○●●	

따라서, ☆☆☆☆처(○○○○○부)는 회사의 중요 정보가 유출되지 않도록 명확한 OTP 단말 예외 처리 기준 및 절차를 수립하여 OTP 단말 예외 처리를 할 필요가 있으며, OTP 단말 분실신고 기능오류를 수정하고 화면 OTP(1.5팩터)권한이 부여되어 있는 사용자 계정을 재검토할 필요가 있다.

관계부서 의견

☆☆☆☆처는 OTP 시스템 권한 관리와 관련하여 업무처리가 미흡하였음을 인정하였고, 향후 유사사례가 발생하지 않도록 업무처리에 만전을 기하겠다는 의견을 제시하였다.

조치할 사항 ☆☆☆☆처장은

- ① OTP 예외 처리가 적절하게 이루어질 수 있도록 OTP 예외 기준 및 절차를 마련하시고, (개선)
- ② 화면OTP(1.5팩터)가 부여되어 있는 사용자 계정을 재검토하고 사용기간이 종료된 계정에 대해 권한을 회수하시기 바랍니다. (시정)